



CIS GOOGLE KUBERNETES ENGINE AUTOPILOT BENCHMARK



GVHD: ThS. Trần Thị Dung, ThS. Văn Thiên Luân

Sinh viên thực hiện:

- Đinh Huỳnh Gia Bảo (22520101)
- Nguyễn Xuân Cường (22520178)

NỘI DUNG



01. TỔNG QUAN

- Giới thiệu **Kubernetes**, **Google Kubernetes Engine** và **Center for Internet Security Benchmark**, mục tiêu đề án, phạm vi đánh giá.



02. NHÓM KHUYẾN NGHỊ

- Các nội dung **kỹ thuật chính**: RBAC và Service Accounts, Pod Security Standards, Namespace Policies và Cluster Networking.



03. PHƯƠNG PHÁP TRIỂN KHAI

- Giới thiệu **công cụ sử dụng** và **các bước thực hiện**



04. ĐÁNH GIÁ VÀ KẾT LUẬN

- **Đánh giá phương pháp** kiểm tra, khắc phục và so sánh mức độ tuân thủ giữa **Autopilot** và **Standard**.
- **Tổng hợp kết quả** và phần thảo luận (Q&A).



01.

TỔNG QUÁT

Giới thiệu **Kubernetes**, **Google Kubernetes Engine (GKE)** và **Center for Internet Security (CIS) Benchmark**, đồng thời làm rõ mục đích của đề án trong việc tuân thủ các quy tắc CIS nhằm nâng cao mức độ an toàn hệ thống.

BỐI CẢNH THỰC TẾ

➡ Sự chuyển dịch

Doanh nghiệp đang chuyển dần hạ tầng lên Cloud nhằm đáp ứng **nhu cầu mở rộng nhanh, giảm chi phí vận hành và tăng tính linh hoạt.**

➡ Tăng trưởng của Kubernetes

Kubernetes trở thành nền tảng **tiêu chuẩn** để triển khai dịch vụ nhờ khả năng **tự động hóa, scale linh hoạt** và **quản lý workload** thống nhất trên nhiều môi trường.

➡ Rủi ro bảo mật

Sai lệch cấu hình là nguyên nhân **lớn nhất** dẫn đến rủi ro bảo mật, đặc biệt trong môi trường Kubernetes phân tán và nhiều thành phần như GKE.

➡ Nhu cầu đánh giá an toàn

Cần một bộ tiêu chí **chuẩn hóa** để **đánh giá mức độ bảo mật** của GKE, trong đó **CIS Benchmark** là tài liệu được công nhận rộng rãi.

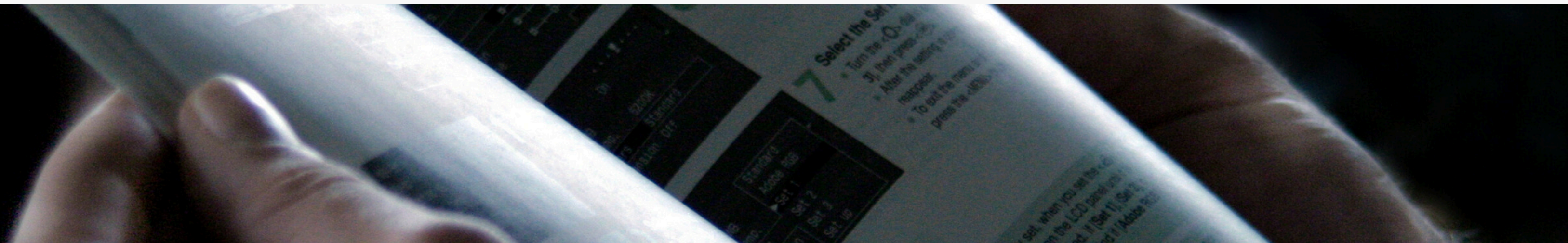
MỤC TIÊU VÀ PHẠM VI

➔ MỤC TIÊU

- Đánh giá **mức độ tuân thủ** CIS Benchmark đối với GKE.
- Xác định các cấu hình **chưa đáp ứng yêu cầu** và đề xuất **hướng khắc phục**.

➔ PHẠM VI

- Đánh giá trên **GKE Standard** và **Autopilot** Mode.
- Tập trung vào các công việc thuộc **Level 1** của nhóm khuyến nghị liên quan



KUBERNETES?



Kubernetes, hay còn gọi là **K8s**, là một hệ thống **mã nguồn mở** dùng để tự động hóa việc triển khai, mở rộng và quản lý các ứng dụng chạy trong container.

Mở rộng linh hoạt

Cho phép mở rộng hoặc thu nhỏ ứng dụng theo nhu cầu mà không gián đoạn dịch vụ.

Khả năng phục hồi

Tự động thay thế hoặc khởi động lại các container bị lỗi, đảm bảo ứng dụng luôn sẵn sàng.

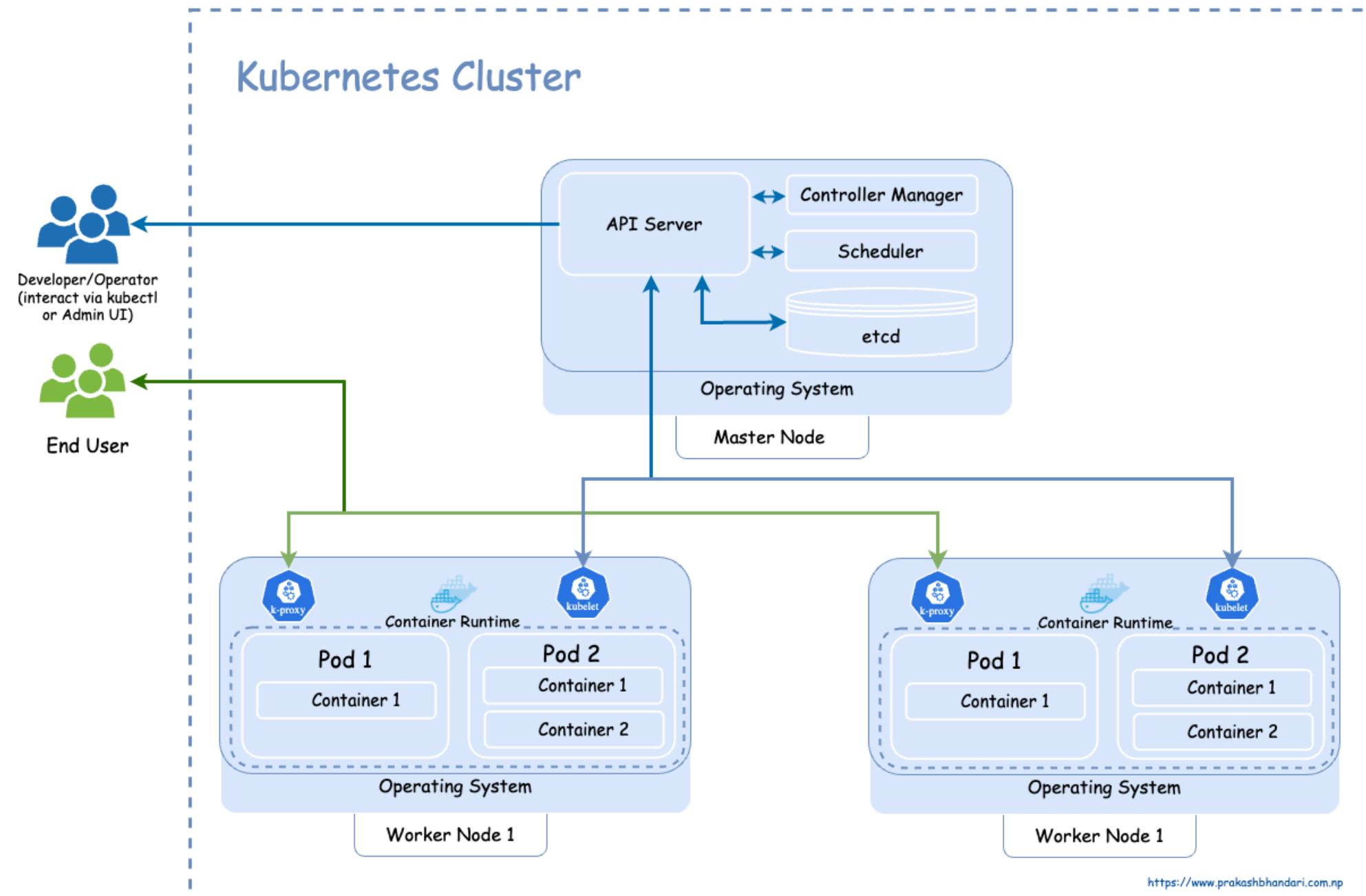
Cân bằng tải và phát hiện dịch vụ

Tự động phân phối lưu lượng và tìm kiếm các dịch vụ trong cụm.

Triển khai và phục hồi tự động

Tự động triển khai các bản cập nhật của ứng dụng và khôi phục phiên bản trước nếu xảy ra sự cố.

KIẾN TRÚC K8S



Kiến trúc của K8s tuân thủ theo **mô hình client-server** và bao gồm nhiều thành phần phối hợp với nhau để quản lý các ứng dụng được đóng gói dưới dạng container.

Master Node

Master Node / Control Plane chịu trách nhiệm **duy trì trạng thái mong muốn của cluster** và **quản lý các worker node**

Worker Node

Worker nodes chịu trách nhiệm **chạy các ứng dụng** được đóng gói dưới dạng container.

GOOGLE KUBERNETES ENGINE?

GKE, hay Google Kubernetes Engine, là dịch vụ Kubernetes **được quản lý bởi Google Cloud**, cho phép người dùng triển khai, quản lý và mở rộng các ứng dụng container hóa.

GKE có thể:

- **Tự động hóa** thiết lập, **cập nhật** và **mở rộng** cluster.
- Giúp **tập trung vào ứng dụng** thay vì hạ tầng.
- **Tích hợp dịch vụ Google Cloud** nâng cao tính năng.
- Bao gồm **bảo mật tích hợp** và **cân bằng tải**.



SO SÁNH

TIÊU CHÍ	AUTOPILOT GKE	STANDARD GKE
Mô hình vận hành	Google quản lý hầu hết cấu hình và vận hành cluster, tối ưu hoá theo best practices mặc định	Người dùng toàn quyền điều khiển nodes, cấu hình cluster, và chính sách vận hành
Quản lý tài nguyên	Tự động tối ưu hoá tài nguyên, tính phí theo pod, người dùng không cần quản lý node	Người dùng tự quản lý node, node pool, autoscaling và tối ưu chi phí
Mức độ tùy chỉnh	Giới hạn tùy chỉnh để đảm bảo an toàn và tính ổn định của Autopilot	Tự do tùy chỉnh hầu như mọi thành phần: node, mạng, bảo mật, addon, ...

CENTER FOR INTERNET SECURITY

Center for Internet Security (CIS) là một tổ chức **phi lợi nhuận** chuyên thúc đẩy các thực hành bảo mật cho hệ thống của các doanh nghiệp.

Giúp các tổ chức **bảo vệ** hệ thống và dữ liệu **khỏi các mối đe dọa mạng** thông qua các tiêu chuẩn và công cụ bảo mật.



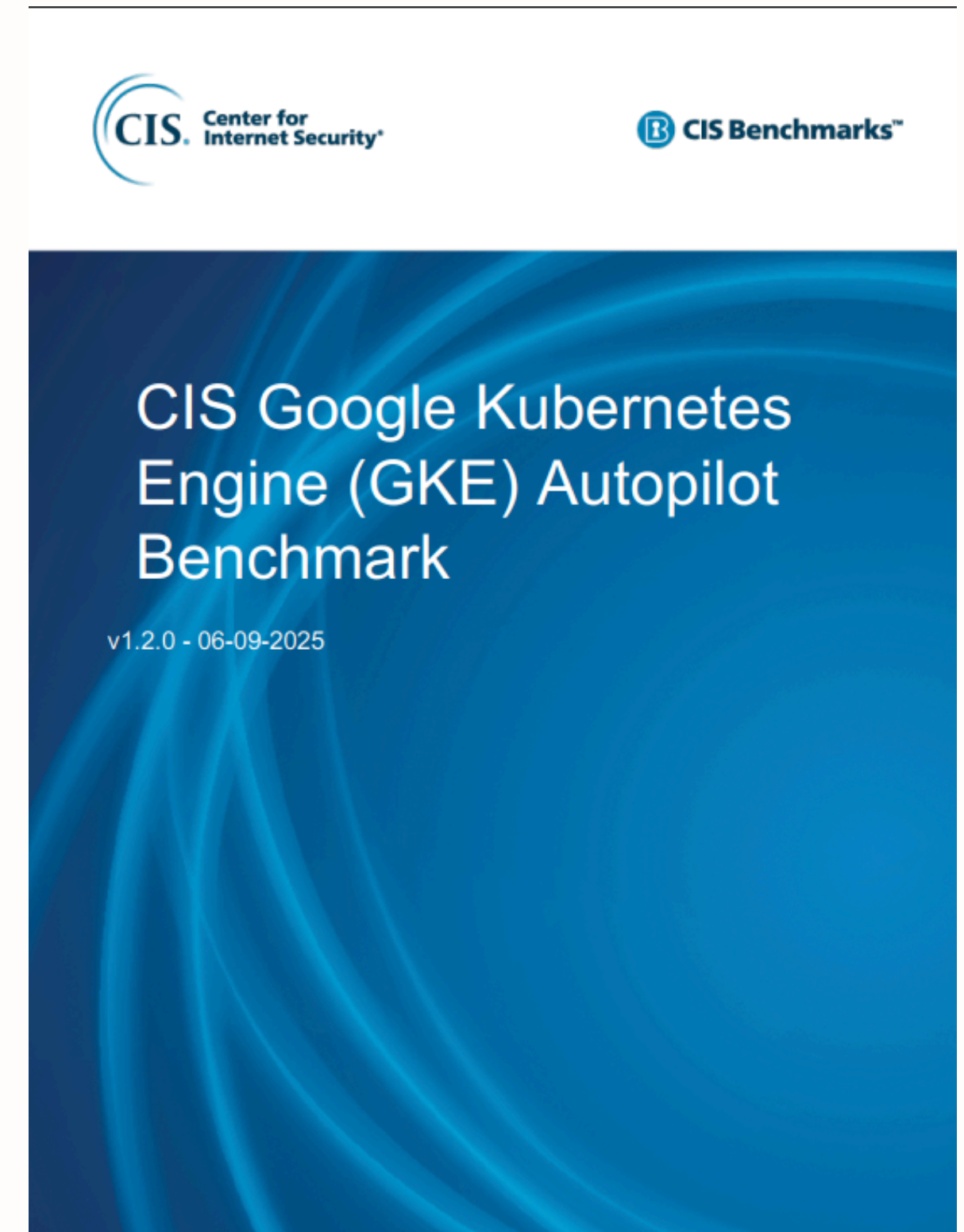
CIS nổi tiếng với việc phát triển bộ **CIS Controls** và **CIS Benchmarks**,

- **CIS Controls** tập hợp các thực hành bảo mật mạng được thiết kế theo hướng chỉ dẫn và ưu tiên.
- **CIS Benchmarks** cung cấp các hướng dẫn cấu hình cụ thể để bảo vệ hệ thống và phần mềm.

CIS GOOGLE KUBERNETES ENGINE AUTOPILOT BENCHMARK

CIS GKE Autopilot Benchmark là bộ tiêu chuẩn bảo mật do Center for Internet Security xây dựng nhằm giúp các tổ chức **đánh giá** và **xây dựng mức an toàn** cho môi trường GKE Autopilot.

Bộ tiêu chuẩn cung cấp hướng dẫn **cấu hình tối ưu, giảm thiểu rủi ro** và đảm bảo cụm Kubernetes vận hành theo các thực hành bảo mật được công nhận rộng rãi.



VÌ SAO CẦN PHẢI TUÂN THỦ CIS?



Chuẩn bảo mật

Được xây dựng dựa trên **sự đồng thuận** của các chuyên gia bảo mật, cung cấp một giải pháp an toàn cho GKE Autopilot

Giảm rủi ro bảo mật

Luôn cần trọng với mọi cấu hình, nếu làm sai có thể tạo lỗ hổng tấn công cho hacker

Kiểm toán và tuân thủ

Tuân thủ giúp tổ chức **đạt các chứng chỉ** hoặc **yêu cầu pháp lý**

Bảo mật và vận hành

Phân loại khuyến nghị thành **Automated** và **Manual**, đồng thời chia theo **Level 1** (ít ảnh hưởng) và **Level 2** (cần bảo mật cao)

Giám sát sự cố

Giúp **phát hiện** và **phản ứng nhanh** khi có sự cố.

ĐỊNH NGHĨA KHUYẾN NGHỊ

Các nội dung sau đây **mô tả những thành phần được bao gồm** trong một khuyến nghị CIS khi áp dụng:

Title

- Mô tả ngắn gọn về cấu hình mà khuyến nghị hướng tới.

Rationale Statement

- Giải thích **lý do** và **tầm quan trọng** của khuyến nghị.

Remediation Procedure

- Hướng dẫn **áp dụng khuyến nghị** để đưa hệ thống vào trạng thái tuân thủ.

Profile

- Chia thành **level 1** (ít ảnh hưởng đến tính năng) và **level 2** (mở rộng level 1)

Impact Statement

- Nêu các **ảnh hưởng** về bảo mật, chức năng hoặc vận hành.

Default Value

- Giá trị mặc định của thiết lập (nếu có).



Description

- **Thông tin chi tiết** về thiết lập liên quan

Audit Procedure

- Hướng dẫn **kiểm tra hệ thống** có tuân thủ khuyến nghị hay không.

References

- Tài liệu tham khảo bổ sung liên quan đến khuyến nghị.

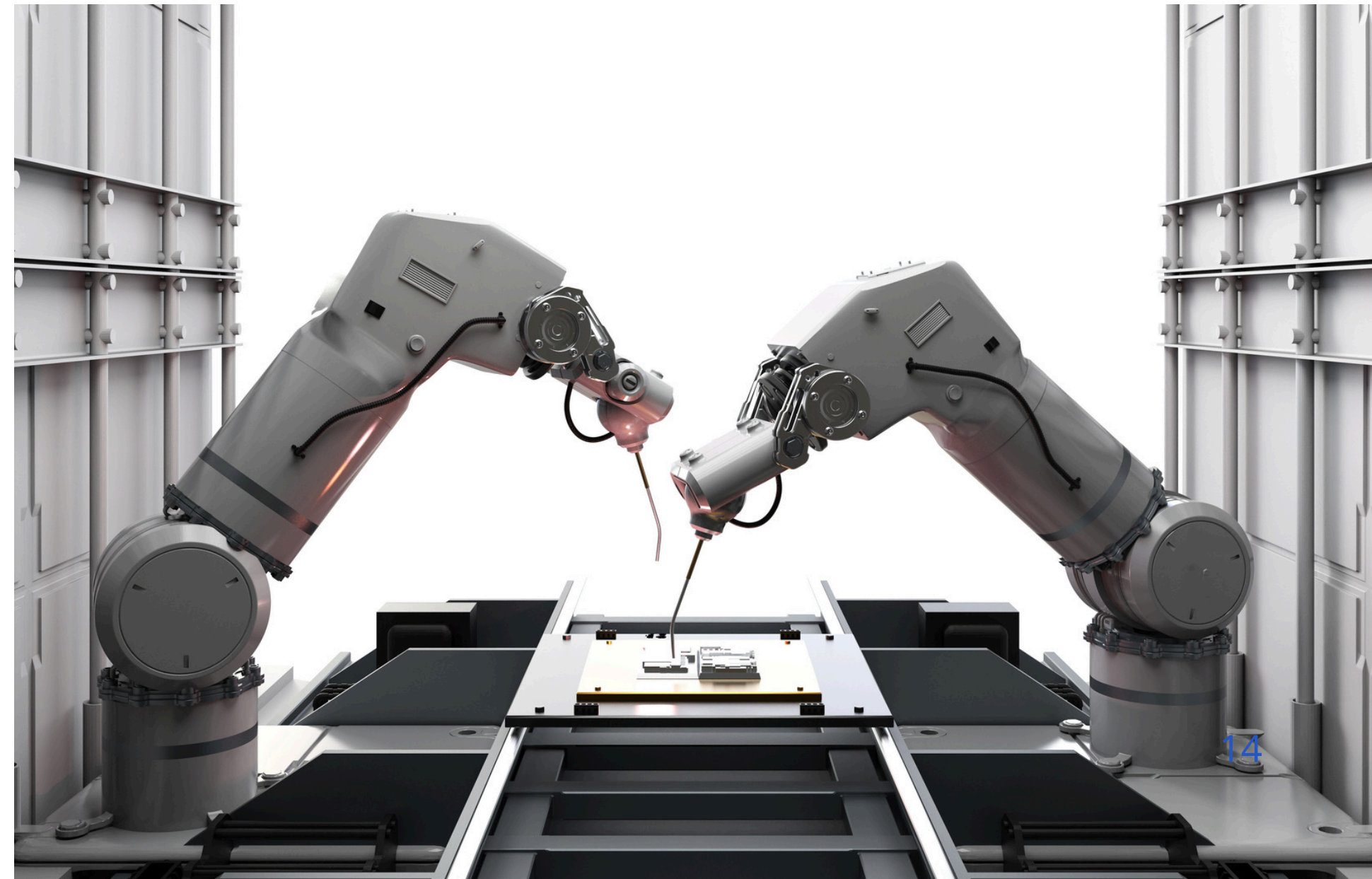
Tình trạng đánh giá

★ Automated

- Kiểm tra hoàn toàn tự động và trả kết quả **pass/fail**.
- Có **hướng dẫn rõ ràng** để triển khai automation.

★ Manual

- **Không thể đánh giá hoàn toàn** bằng **automation**.
- Cần bước **kiểm tra thủ công** để xác thực cấu hình.
- Trạng thái kỳ vọng có thể **khác nhau** giữa các môi trường.





02.

NHÓM KHUYẾN NGHỊ

Giới thiệu công nghệ sử dụng và phương pháp để thực thi CIS GKE Autopilot Benchmark xoay quanh hai nhóm nội dung trọng tâm: **Policies** và **Managed Services**. Hai phần này bao quát toàn bộ các khía cạnh bảo mật quan trọng của một cụm Kubernetes trong chế độ Autopilot và Standard.

POLICIES

RBAC và Service Account

Cần thiết lập **cơ chế phân quyền** tối thiểu, **tránh lạm dụng** các quyền đặc biệt và đảm bảo người dùng chỉ có **đúng phạm vi truy cập** cần thiết.

Pod Security Standards

Bắt buộc áp dụng Pod Security Standard ở mức **Baseline** hoặc cao hơn để **ngăn chặn** các cấu hình pod rủi ro.

General Policies

Việc **tổ chức tài nguyên theo namespace**, áp dụng các quy tắc bảo mật giúp **tăng tính tách biệt**, kiểm soát và an toàn cho toàn bộ cụm GKE.

NỘI DUNG NHÓM POLICIES



RBAC and Service Accounts

- Đảm bảo vai trò **cluster-admin** chỉ được sử dụng khi cần thiết (Automated)
- Giảm thiểu việc sử dụng **ký tự đại diện** (wildcard) trong Roles và ClusterRoles (Automated)
- Giới hạn việc sử dụng quyền **Bind**, **Impersonate** và **Escalate** trong Kubernetes cluster (Manual)

Pod Security Standards

- Đảm bảo cụm áp dụng và thực thi hồ sơ **Pod Security Standard Baseline** hoặc nghiêm ngặt hơn cho tất cả các namespace (Manual)

General Policies

- Tạo **ranh giới quản trị** giữa các tài nguyên bằng cách sử dụng namespaces (Manual)

Managed Services



Cluster Networking

Thiết lập và áp dụng Network Policies để **kiểm soát luồng giao tiếp** giữa các workload, đảm bảo phân tách và giảm thiểu rủi ro trong cụm GKE.

NỘI DUNG NHÓM MANAGED SERVICES



Cluster Networking

- Bật **VPC Flow Logs** và khả năng quan sát lưu lượng nội bộ giữa các node (Automated)

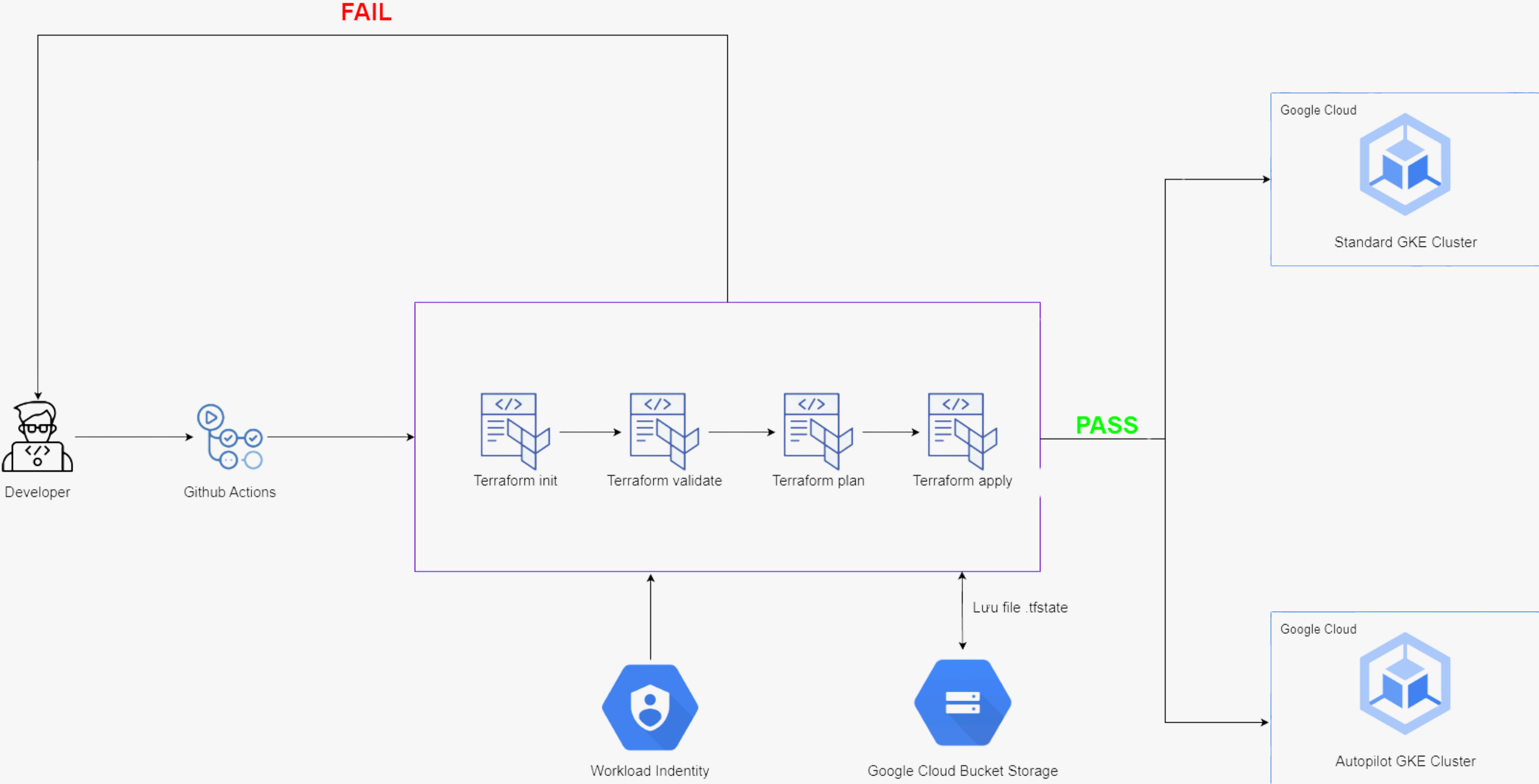


03.

PHƯƠNG PHÁP TRIỂN KHAI

Mô tả các **công cụ được sử dụng** và **phương pháp triển khai** theo từng bước trên cụm GKE, kết hợp thực hiện đầy đủ các kiểm soát **Level 1** của CIS nhằm bảo đảm hạ tầng được cấu hình nhất quán, tránh rủi ro bảo mật và phù hợp với tiêu chuẩn đánh giá.

MÔ HÌNH KIẾN TRÚC



CÔNG CỤ

TERRAFORM



Terraform

Tự động hóa việc khởi tạo Cluster bằng cách sử dụng **laC (Infrastructure as Code)**

GOOGLE CLOUD SDK SHELL



Google
Cloud
SDK

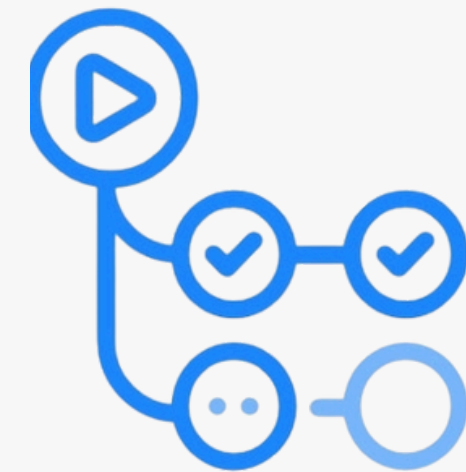
Cung cấp môi trường **gcloud CLI** để **tương tác** và **quản lý tài nguyên** GKE qua dòng lệnh.

BASH SCRIPT



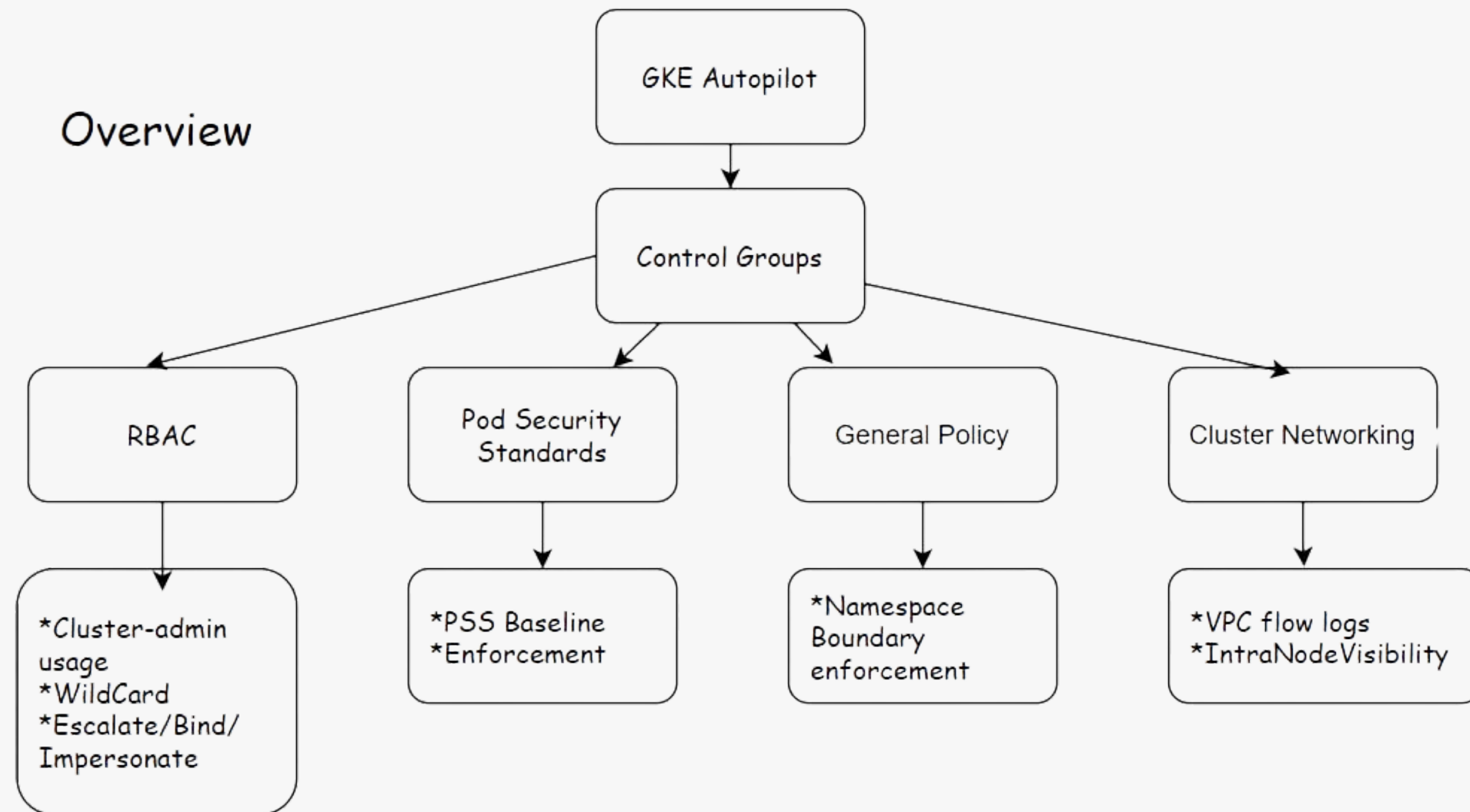
Thực hiện tạo kịch bản **tự động hóa** để tuân thủ các tiêu chí CIS.

GITHUB ACTIONS

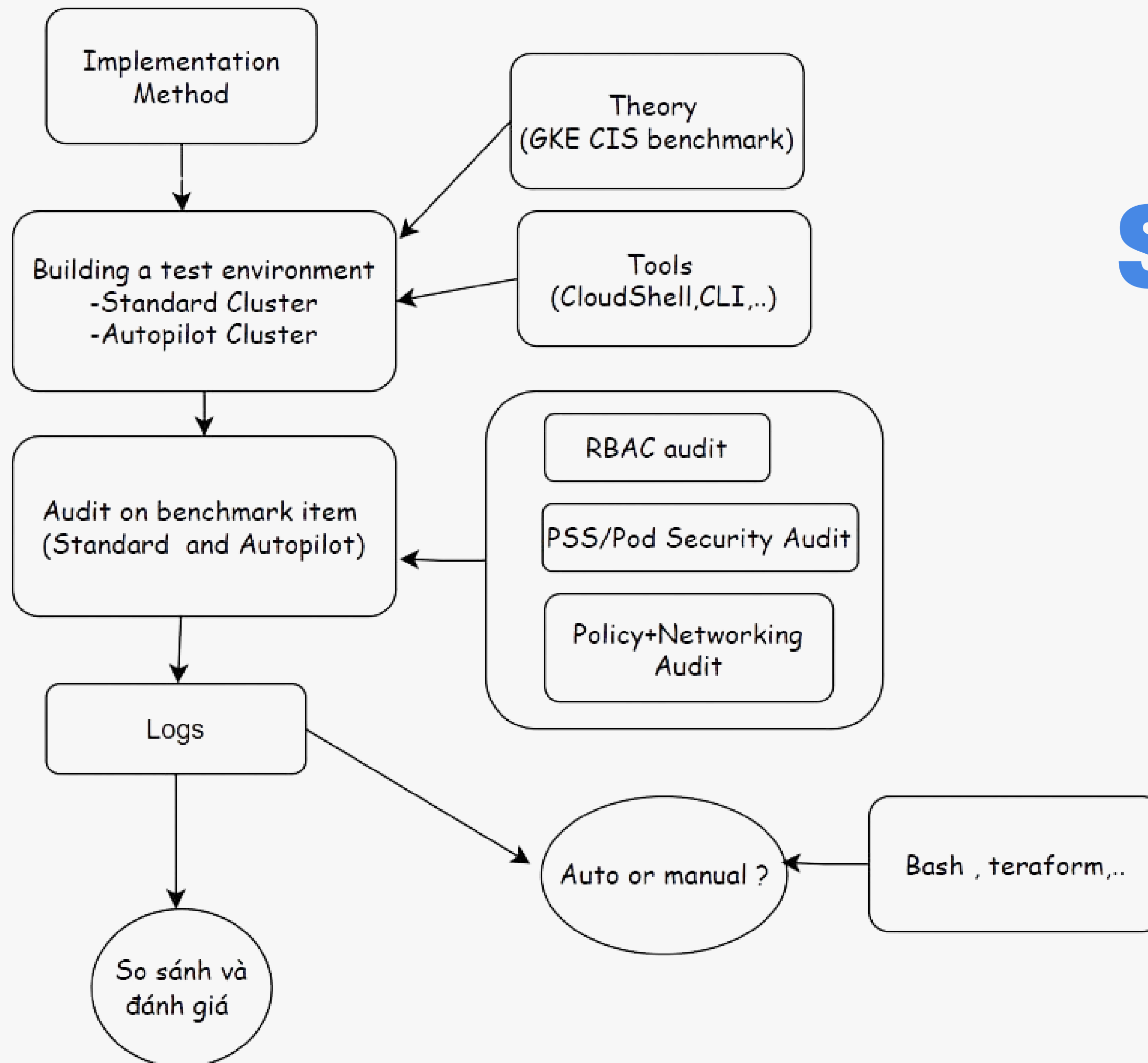


Tự động hóa quy trình từ khi nhận mã nguồn mới đến khi triển khai

MÔ HÌNH TRIỂN KHAI

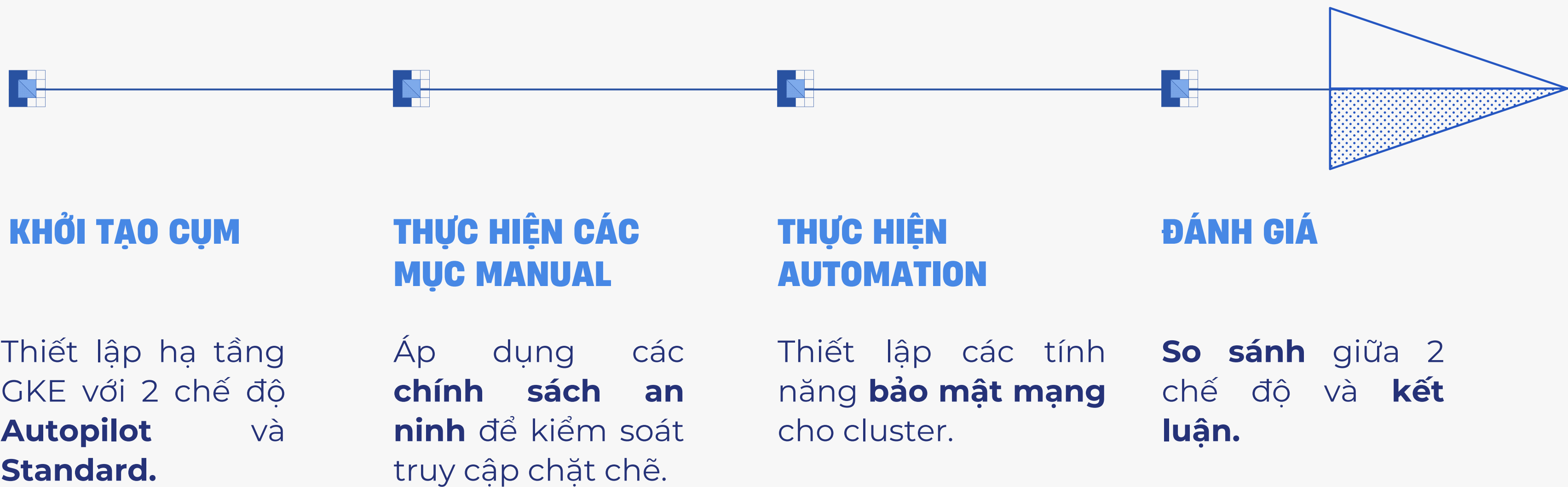


SƠ ĐỒ LƯUỒNG CÔNG VIỆC



QUY TRÌNH TRIỂN KHAI

Các bước thiết lập hạ tầng GKE an toàn và tuân thủ chuẩn CIS



KHỞI TẠO CỤM STANDARD GKE

```
gcp-infr/
├── main.tf           # Root module: orchestrates all child modules
├── variable.tf       # Input variable definitions for the root module
├── output.tf         # Output values exposed from the root module
├── terraform.tfvars  # Default configuration values
├── module/
│   ├── vpc/          # VPC module: networking, subnets, routing, firewall rules
│   │   ├── main.tf
│   │   ├── variable.tf
│   │   └── output.tf
│   ├── gke/          # GKE module: GKE cluster configuration
│   │   ├── main.tf
│   │   ├── variable.tf
│   │   └── output.tf
│   └── node_pool/    # Node Pool module: worker nodes, autoscaling, machine types
│       ├── main.tf
│       ├── variable.tf
│       └── output.tf
└── README.md        # Documentation of the project
```

KHỞI TẠO CỤM AUTOPILOT GKE

```
gcp-gke-infr/autopilot/  
├── backend.tf          # Remote state configuration (GCS)  
├── main.tf             # GKE Autopilot cluster resource  
├── provider.tf         # Terraform and Google provider config  
├── terraform.tfvars    # Variable values (customize this)  
├── variable.tf         # Input variable definitions  
└── output.tf          # Output values after deployment
```


KẾT QUẢ SAU KHI TẠO

Google Cloud

CIS GKE Autopilot Benchmark

Search (/) for resources, docs, products, and more

Search

✦ 📄 🔔 ⓘ ⋮ 👤

Kubernetes Engine / Clusters

All Fleets

No fleets in the current project

Resource Management

Overview

Clusters

Workloads

AI/ML New

Teams

Applications

Secrets & ConfigMaps

Storage

Object Browser

Upgrades New

Backup for GKE

Posture Management

Marketplace

Release Notes

<|

Kubernetes clusters

+ Create + Deploy ↻ Refresh 📄 Attach cluster New

Learn

Overview

Utilization

Observability

Cost Optimization

Health ⓘ

100% healthy

View 2 recommendations

Upgrade ⓘ

100% up to date

View 2 recommendations

Estimated monthly cost ⓘ

₫0.00 / month · 0%

No recommendations

Filter

En

ⓘ

☰

☐ Status	Name ↑	Location	Mode	Number of nodes	Total vCPUs	Total memory	Notifications	Labels	
☐ ✓	autopilot-cluster	asia-southeast1	Autopilot		0	0 GB	🔔 Create a backup plan 🔔 Set maintenance window	goog-terra... : true	⋮
☐ ✓	cis-standard-cluster-v2	asia-southeast1-a	Standard	2	4	8 GB	🔔 Create a backup plan 🔔 Set maintenance window	cluster : cis-standard-v2	▼ ⋮



THỰC HIỆN CÁC MỤC MANUAL

Đảm bảo vai trò cluster-admin chỉ được sử dụng khi cần thiết

Audit:

> kubectl get clusterrolebinding -o json

```
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl get clusterrolebinding -o json \
| jq -r '
  .items[]
| select(.roleRef.name=="cluster-admin")
| [
  .metadata.name,
  .roleRef.name,
  (.subjects[]?.name // "none")
]
| @tsv'
cluster-admin    cluster-admin    system:masters
```

(Standard+ autopilot)

Đảm bảo vai trò cluster-admin chỉ được sử dụng khi cần thiết

Remediation

Standard : - delete clusterrolebinding <>

Autopilot : - delete clusterrolebinding <>

- enforce chặn non-admin bind cluster-admin

```
xuancuongchywiz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl create sa -n default cis-test-sa
serviceaccount/cis-test-sa created
```

```
xuancuongchywiz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl auth can-i "*" "
*" --as=system:service:default:cis-test-sa
no
xuancuongchywiz1@cloudshell:~ (cis-gcp-benchmark)$ gcloud container cluster
s describe autopilot-cluster --region asia-southeast1 --format="value(a
utopilot.enabled)"
True
```

Giảm thiểu việc sử dụng ký tự đại diện (wildcard) trong Roles và ClusterRoles

Audit

- > kubectl get roles --all-namespaces -o yaml
- > kubectl get clusterroles --all-namespaces -o yaml

```
giabaoctg@cloudshell:~ (cis-gcp-benchmark)$ kubectl get roles --all-namespaces -o json | jq -r '
.items[]
| select(
  (.rules[]?.verbs[]? == "*") or
  (.rules[]?.apiGroups[]? == "*") or
  (.rules[]?.resources[]? == "*") or
  (.rules[]?.resourceNames[]? == "*")
)
| .metadata.namespace + "/" + .metadata.name
'
```

```
giabaoctg@cloudshell:~ (cis-gcp-benchmark)$
```


Giảm thiểu việc sử dụng ký tự đại diện (wildcard) trong Roles và ClusterRoles

Remediation

- Tạo wildcard clusterrole

```
apiVersion: rbac.authorization.k8s.io/v1
kind: ClusterRole
metadata:
  name: cis-wildcard-test
rules:
- apiGroups: ["*"]
  resources: ["*"]
  verbs: ["*"]
```

Standard

> kubectl get role cis-wildcard-test -o yaml

- Bind clusterrole cho SA

```
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl create clusterrolebinding wildcard-sa-test --clusterrole=wildcard-check --serviceaccount=default:cis-test-ca
clusterrolebinding.rbac.authorization.k8s.io/wildcard-sa-test created
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$
```


Giảm thiểu việc sử dụng ký tự đại diện (wildcard) trong Roles và ClusterRoles

Remediation

- Autopilot

Mặc định sẽ chặn các non-admin tạo wildcard binding role và clusterrole

```
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl auth can-i get nodes -  
-as=system:serviceaccount:default:cis-wildcard-sa-test  
Warning: resource 'nodes' is not namespace scoped  
  
no
```

Giới hạn việc sử dụng quyền Bind, Impersonate và Escalate trong Kubernetes cluster

Audit

- > `kubectl get clusterrolebinding -o yaml | grep -A5 -E "bind|impersonate|escalate"`
- > `kubectl get rolebinding --all-namespaces -o yaml | grep -A5 -E "bind|impersonate|escalate"`

```
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl get clusterrolebinding
-o yaml | grep -A5 -E "bind|impersonate|escalate"
  name: anet-operator-role-binding
  resourceVersion: "1765380351245839014"
  uid: c27ef8ba-aa08-4591-bc50-a0523af1b564
  roleRef:
    apiGroup: rbac.authorization.k8s.io
    kind: ClusterRole
  --
    {"apiVersion":"rbac.authorization.k8s.io/v1","kind":"ClusterRoleBinding",
"metadata":{"annotations":{},"name":"cis-escalate-bind-impersonate-binding"},"rol
eRef":{"apiGroup":"rbac.authorization.k8s.io","kind":"ClusterRole","name":"cis-es
calate-bind-impersonate-test"},"subjects":[{"kind":"ServiceAccount","name":"cis-t
est-sa","namespace":"default"}]}
```

Giới hạn việc sử dụng quyền Bind, Impersonate và Escalate trong Kubernetes cluster

Remendiation

> kubectl get clusterrole/clusterrolebinding <> -o yaml

```
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl get clusterrolebinding
-o yaml | grep -A5 -E "bind|impersonate|escalate"
  name: anet-operator-role-binding
  resourceVersion: "1765380351245839014"
  uid: c27ef8ba-aa08-4591-bc50-a0523af1b564
  roleRef:
    apiGroup: rbac.authorization.k8s.io
    kind: ClusterRole
  --
    {"apiVersion":"rbac.authorization.k8s.io/v1","kind":"ClusterRoleBinding",
"metadata":{"annotations":{},"name":"cis-escalate-bind-impersonate-binding"},"rol
eRef":{"apiGroup":"rbac.authorization.k8s.io","kind":"ClusterRole","name":"cis-es
calate-bind-impersonate-test"},"subjects":[{"kind":"ServiceAccount","name":"cis-t
est-sa","namespace":"default"}]}
```

Đảm bảo cụm áp dụng và thực thi hồ sơ Pod Security Standard Baseline hoặc nghiêm ngặt hơn cho tất cả các namespace

Audit

Standard : `kubectl get clusterrole/clusterrolebinding <name> -o yaml`

```
xuancuongchwyiz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl get ns --show-labels
NAME                STATUS   AGE   LABELS
default             Active   42h   kubernetes.io/metadata.name=default
gke-managed-cim      Active   42h   addonmanager.kubernetes.io/mode=Reconcile,kubernetes.io/metadata.name=gke-managed-cim
gke-managed-dpv2-observability Active   42h   addonmanager.kubernetes.io/mode=Reconcile,kubernetes.io/metadata.name=gke-managed-dpv2-observability
gke-managed-system  Active   42h   addonmanager.kubernetes.io/mode=Reconcile,kubernetes.io/metadata.name=gke-managed-system
gke-managed-volumepopulator Active   42h   addonmanager.kubernetes.io/mode=Reconcile,k8s-app=gke-volume-populator,kubernetes.io/metadata.name=gke-managed-volumepopulator
gmp-public          Active   42h   addonmanager.kubernetes.io/mode=Reconcile,kubernetes.io/metadata.name=gmp-public
gmp-system          Active   42h   addonmanager.kubernetes.io/mode=Reconcile,kubernetes.io/metadata.name=gmp-system
kube-node-lease     Active   42h   kubernetes.io/metadata.name=kube-node-lease
kube-public         Active   42h   kubernetes.io/metadata.name=kube-public
kube-system         Active   42h   kubernetes.io/metadata.name=kube-system
```

Đảm bảo cụm áp dụng và thực thi hồ sơ Pod Security Standard Baseline hoặc nghiêm ngặt hơn cho tất cả các namespace

Audit

Autopilot :Chặn các non-admin user có các quyền bind/imperonate/escalate

```
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl auth can-i create clusterrolebinding --as=system:serviceaccount:default:cis-test-sa
Warning: resource 'clusterrolebindings' is not namespace scoped in group 'rbac.authorization.k8s.io'
no
```

```
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl auth can-i escalate clusterrolebinding --as=system:serviceaccount:default:cis-test-sa
Warning: resource 'clusterrolebindings' is not namespace scoped in group 'rbac.authorization.k8s.io'
no
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl auth can-i impersonate clusterrolebinding --as=system:serviceaccount:default:cis-test-sa
Warning: resource 'clusterrolebindings' is not namespace scoped in group 'rbac.authorization.k8s.io'
no
```


Đảm bảo cụm áp dụng và thực thi hồ sơ Pod Security Standard Baseline hoặc nghiêm ngặt hơn cho tất cả các namespace

Check

- > Tạo một pod vi phạm privileged
- > Kubectl apply yaml
- > PSS sẽ chặn pod này

```
GNU nano 7.2
apiVersion: v1
kind: Pod
metadata:
  name: privileged
  namespace: dev-environment
spec:
  containers:
  - name: attacker
    image: busybox
    command: ["sleep", "3600"]
    securityContext:
      privileged: true
```

```
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl apply -f privileged.yaml
Error from server (Forbidden): error when creating "privileged.yaml": pods "privileged" is forbidden: violates PodSecurity "baseline:latest": privileged (container "attacker" must not set securityContext.privileged=true)
```


Đảm bảo cụm áp dụng và thực thi hồ sơ Pod Security Standard Baseline hoặc nghiêm ngặt hơn cho tất cả các namespace

Remediation

Standard: Kích hoạt Pod Security Standards cho namespace của người dùng.

```
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl label ns dev-environment pod-security.kubernetes.io/enforce=baseline \
> pod-security.kubernetes.io/enforce=baseline \
> pod-security.kubernetes.io/audit=baseline \
> pod-security.kubernetes.io/warn=baseline
namespace/dev-environment labeled
```

Autopilot: PSS được kích hoạt mặc định.

```
Warning: autopilot-default-resources-mutator:Autopilot updated Pod default/privileged-pod: defaulted unspecified 'cpu' resource for containers [test] (see http://g.co/gke/autopilot-defaults).
Error from server (GKE Warden constraints violations): error when creating "privileged.yaml": admission webhook "warden-validating.common-webhooks.networking.gke.io" denied the request: GKE Warden rejected the request because it violates one or more constraints.
Violations details: {"[denied by autogke-disallow-privilege]":["container test is privileged; not allowed in Autopilot"]}
Requested by user: 'xuancuongchyz1@gmail.com', groups: 'system:authenticated'.
```

Tạo ranh giới quản trị giữa các tài nguyên bằng cách sử dụng namespaces

Audit

>kubectl get role ns -n <namespace of role > -o json

```
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl get role -n dev
NAME          CREATED AT
dev-role      2025-11-26T06:56:18Z
```

```
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl get role -n dev -o json
{
  "apiVersion": "v1",
  "items": [],
  "kind": "List",
  "metadata": {
    "resourceVersion": ""
  }
}
```

Tạo ranh giới quản trị giữa các tài nguyên bằng cách sử dụng namespaces

Remediation

Standard cluster: Check namespace của role để đảm bảo role không truy cập các tài nguyên của namespace khác

```
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl get role -n dev
NAME          CREATED AT
dev-role      2025-11-26T06:56:18Z
```

```
xuancuongchyz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl get role -n dev -o json
{
  "apiVersion": "v1",
  "items": [],
  "kind": "List",
  "metadata": {
    "resourceVersion": ""
  }
}
```

Tạo ranh giới quản trị giữa các tài nguyên bằng cách sử dụng namespaces

Remendiation

Autopilot: Role chỉ có quyền hạn trong một namespace cụ thể

```
xuancuongchywiz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl get sa cis-test-sa -n default
```

NAME	SECRETS	AGE
cis-test-sa	0	48m

```
xuancuongchywiz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl get role -n dev
```

NAME	CREATED AT
dev-role	2025-11-26T06:56:18Z

- Lấy một pod trong namespace dev

```
xuancuongchywiz1@cloudshell:~ (cis-gcp-benchmark)$ kubectl auth can-i get pods --namespace=dev --as=system:serviceaccount:default:cis-test-sa
no
xuancuongchywiz1@cloudshell:~ (cis-gcp-benchmark)$ gcloud container clusters describe autopilot-cluster --region asia-southeast1 --format="value(autopilot.enabled) "
```

Bật VPC Flow Logs và khả năng quan sát lưu lượng nội bộ giữa các node

Audit

>gcloud compute networks subnets <subnets> --region <> --format(enableFlowLogs)

>gcloud container describe <cluster_name> --region <region> --format(networkConfig.enableIntraNodeVisibility)

```
xuancuongchyz1@cloudshell:~/scripts/scripts (cis-gcp-benchmark)$ gcloud compute networks subnets describe gke-subnet-v2 --region asia-southeast1 --format="value(enableFlowLogs)"
True
xuancuongchyz1@cloudshell:~/scripts/scripts (cis-gcp-benchmark)$
```

```
xuancuongchyz1@cloudshell:~/scripts/scripts (cis-gcp-benchmark)$ gcloud container clusters describe cis-standard-cluster --region asia-southeast1-a --format="value(networkConfig.enableIntraNodeVisibility)"
True
xuancuongchyz1@cloudshell:~/scripts/scripts (cis-gcp-benchmark)$
```


Bật VPC Flow Logs và khả năng quan sát lưu lượng nội bộ giữa các node

Remendiation

Standard

>gcloud compute networks subnets <subnets> --region <> --enable--flow-logs
>gcloud compute networks subnets <subnets> --region <> --enable-intra-node-visibility

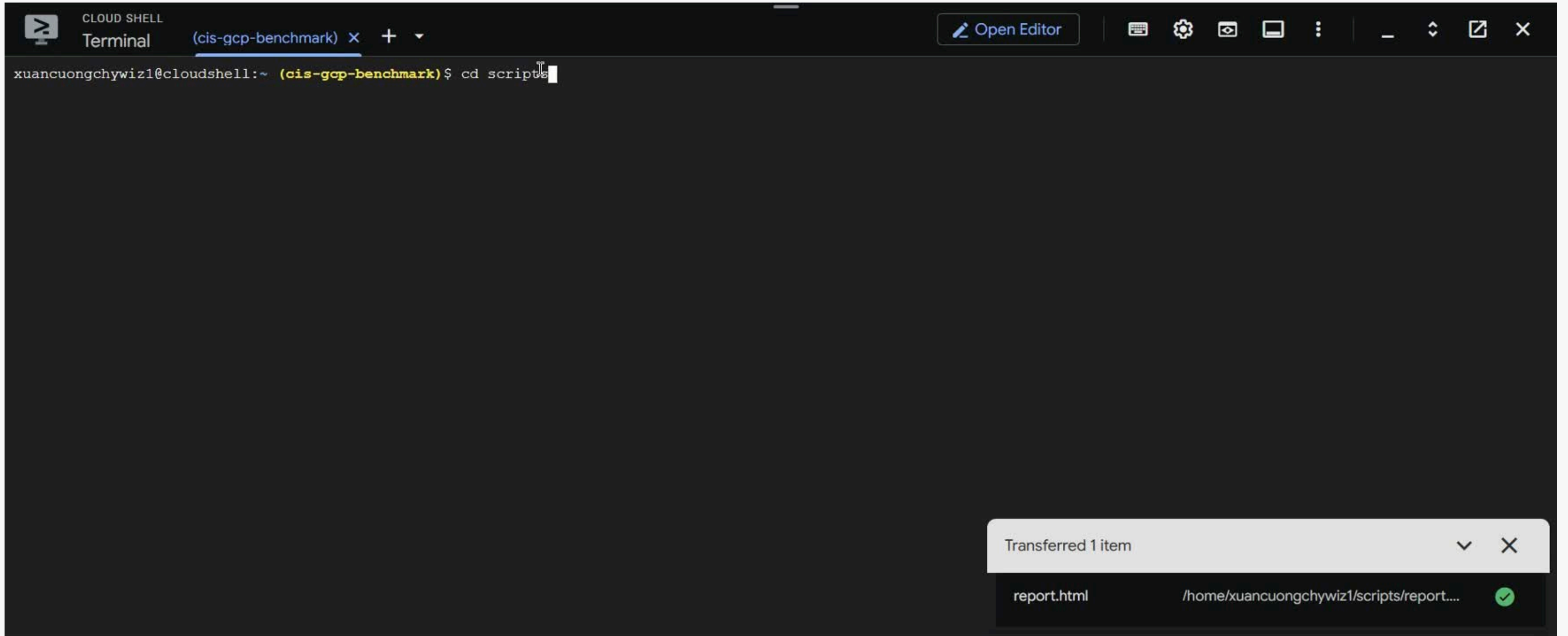
```
xuancuongchywiz1@cloudshell:~ (cis-gcp-benchmark)$ gcloud container clusters update cis-standard-cluster \  
> --region asia-southeast1-a \  
> --enable-intra-node-visibility  
Updating cis-standard-cluster...working  
Updating cis-standard-cluster...done.  
Updated [https://container.googleapis.com/v1/projects/cis-gcp-benchmark/zones/asia-southeast1-a/clusters/cis-standard-cluster].  
To inspect the contents of your cluster, go to: https://console.cloud.google.com/kubernetes/workload_/gcloud/asia-southeast1-a/cis-standard-cluster?project=cis-gcp-benchmark
```

Autopilot: Kích hoạt mặc định



THỰC HIỆN AUTOMATION

VIDEO THỰC HIỆN AUTOMATION



The screenshot shows a Google Cloud Shell terminal window. The top bar includes the 'CLOUD SHELL' logo, a 'Terminal' tab, and a dropdown menu with '(cis-gcp-benchmark)' selected. To the right of the tabs is an 'Open Editor' button and a series of icons for various shell functions. The terminal area is dark with light-colored text. The prompt is 'xuancuongchywiz1@cloudshell:~ (cis-gcp-benchmark)\$' and the command 'cd scripts' has been entered. A notification box in the bottom right corner states 'Transferred 1 item' and lists 'report.html' with its full path and a green checkmark icon.

```
xuancuongchywiz1@cloudshell:~ (cis-gcp-benchmark)$ cd scripts
```

Transferred 1 item

report.html	/home/xuancuongchywiz1/scripts/report....	✓
-------------	---	---



04. ĐÁNH GIÁ VÀ KẾT LUẬN

Đưa ra kết luận và so sánh giữa 2 chế độ GKE

TỔNG KẾT SO SÁNH

Rule	Standard	Autopilot
CIS_4.1.1: Cluster-admin	PASS : audit clusterrole +delete	PASS : enforce admin-cluster
CIS_4.1.3: Wildcard	PASS : audit clusterrole/role + remove sensitive rule	PASS : enforce wildcard
CIS_4.1.7: Impersonate,bind,escalate	PASS : audit clusterrole/role + remove sensitive rule	PASS : enforce bind/escalate/imperonate
CIS_4.2.1: PSS baseline	PASS : audit+manual enforce pod security	PASS : enforce baseline
CIS_4.6.1: Namespace Boundary	PASS : audit+ check role of namespace and manual fix	PASS : enforce role can only access in their namespace
CIS_5.4.1: Enable Flowlogs and intraNodeVisibility	PASS : audit+enable Flowlogs/IntraNode	PASS : auto enable flowlogs and intraNode

**CẢM ƠN THẦY/CÔ VÀ
CÁC BẠN ĐÃ LẮNG NGHE
BUỔI THUYẾT TRÌNH**